

Taller 7 — Opportunities & Solutions

Mejora de arquitectura — IS de Colombia (ISD Colombia)

Cliente: IS de Colombia (ISD Colombia)

Alcance: Procesos 01 y 02: búsqueda/selección de equipos y gestión de solicitudes/cotización.

Versión: Borrador académico consolidado con la evidencia disponible al 2026-09-27.

Nota de trazabilidad: el Taller 7 exige consolidar los Talleres 3, 4, 5 y 6. En esta versión, los hallazgos de seguridad provienen del Taller 5 realizado previamente; las brechas de los Talleres 3, 4 y 6 que no pudieron ser recuperadas se mantienen como “pendientes de validación” y no se inventan. El C1/C2 .drawio aportado no contiene elementos de arquitectura recuperables. El PDF adicional aportado corresponde a RedExpress y se usa solo como referencia visual, no como AS-IS de ISD.

1. Diagnóstico inicial — AS-IS

1.1 Contexto

ISD Colombia comercializa y suministra tecnología y desarrolla soluciones a la medida. El levantamiento del cliente identifica como procesos principales la búsqueda y selección de equipos según especificaciones técnicas y la gestión de solicitudes y cotización de clientes. Actualmente la búsqueda de equipos es manual y el contacto con clientes se realiza por canales informales como WhatsApp y redes sociales, sin CRM ni plataforma formal.

La organización tiene como objetivos estratégicos automatizar procesos para ahorrar tiempo y agilizar la operación, y consolidar la comercialización de soluciones adaptadas a las necesidades de cada cliente.

1.2 Fricciones

F1 — Búsqueda manual: la comparación exige consultar múltiples proveedores y fuentes de Internet y revisar manualmente el cumplimiento de especificaciones.

F2 — Entrada no estructurada: las solicitudes llegan por distintos canales y deben ser interpretadas y centralizadas manualmente.

F3 — Reprocesamiento: el personal debe convertir información libre en datos utilizables para compras y cotización.

F4 — Cotización manual: la salida comercial depende del trabajo de las personas y de la preparación manual de documentos.

1.3 Problemas recurrentes

1. Dependencia de actividades manuales.
2. Información distribuida entre canales y personas.
3. Dependencia del conocimiento de los empleados para buscar y validar.
4. Ausencia de una plataforma central para clientes, solicitudes y cotizaciones.
5. Ausencia de trazabilidad tecnológica formal documentada.
6. Riesgo de que la digitalización futura introduzca nuevos problemas de identidad, integridad, confidencialidad y privilegios si se implementa sin seguridad por diseño.

1.4 Vulnerabilidades y riesgos

El Taller 5 identificó riesgos STRIDE de suplantación, alteración, repudio, divulgación de información, disponibilidad y elevación de privilegios. En este documento estos hallazgos se tratan como **riesgos identificados**, no como incidentes que se hayan demostrado en ISD.

1.5 Brechas consolidadas

La matriz completa está en `matriz-brechas.xlsx`. Las brechas funcionales confirmadas son B01–B06; las B07–B12 proceden del análisis de seguridad; y B13–B15 quedan abiertas para incorporar la evidencia de los Talleres 6, 4 y 3.

2. Propuesta de mejoras

2.1 Lluvia de ideas

ID	Mejora	Horizonte	Cierra
M01	Portal/formulario formal de solicitudes	Quick win / Fase 1	B03-B05
M02	Plataforma ligera de gestión comercial/CRM	Fase 1-2	B03-B05, B07-B11
M03	Motor híbrido de búsqueda y validación técnica	Fase 2	B01-B02, B09
M04	Generador asistido de cotizaciones	Fase 2-3	B06-B09
M05	Repositorio central de documentos	Fase 1-2	B06-B07, B10, B13
M06	Seguridad por diseño: IAM, MFA, RBAC y auditoría	Transversal desde Fase 1	B07-B11
M07	Monitoreo, backup y recuperación	Fase 1-2	B10-B12
M08	Capa de integración/API para terceros y notificaciones	Fase 2-3	B01, B03, B06

2.2 Paquetes priorizados

P1 — Gestión comercial digital. Canal formal + gestión comercial central + controles de identidad y auditoría.

P2 — Búsqueda y validación técnica. Motor híbrido de reglas determinísticas y búsqueda semántica, con revisión humana.

P3 — Cotización y documentos. Generación asistida de cotizaciones + repositorio central de documentos.

Los controles de seguridad no se manejan como una mejora aislada: se integran transversalmente en los tres paquetes.

2.3 Matriz de decisión ponderada

Para el canal de solicitudes se compararon tres patrones: portal a medida, plataforma low-code y suite CRM. Los criterios y pesos se encuentran en `Decision_Intake` del Excel.

Resultado preliminar: la plataforma low-code obtiene 4,15/5 frente a 3,55 del portal a medida y 3,70 de una suite CRM. La sensibilidad de costo, adopción, seguridad y velocidad mantiene a la alternativa B en primer lugar bajo los escenarios ensayados.

Trade-off: menor libertad de diseño frente a desarrollo totalmente a medida, a cambio de rapidez y menor carga operativa.

Para búsqueda/validación se compararon motor híbrido, producto/API de terceros y automatización manual asistida. El motor híbrido obtiene 4,00/5. La decisión se basa en el requisito específico de comprobar el 100 % de la especificación y conservar revisión humana.

3. Arquitectura objetivo (TO-BE)

3.1 TO-BE de Aplicaciones

La arquitectura objetivo separa cuatro capacidades:

1. **Canal y gestión comercial:** portal/formulario y plataforma central de solicitudes/clientes.
2. **Búsqueda y validación:** motor que combina reglas determinísticas, búsqueda semántica y consulta a fuentes externas, manteniendo evidencia de las fuentes.
3. **Cotización y documentos:** generador de cotizaciones con plantillas y aprobación humana, más repositorio central.
4. **Servicios transversales:** identidad, RBAC, auditoría, notificaciones y monitoreo.

Flujo objetivo:

Cliente -> Portal -> Gestión comercial -> Motor de búsqueda/validación -> Cotización -> Aprobación -> Cliente

La arquitectura propuesta **no automatiza el envío final sin control humano**. El analista conserva la responsabilidad de revisar la evidencia y aprobar la propuesta.

3.2 TO-BE de Tecnología

Se propone un patrón cloud-first de baja operación para una organización pequeña, sujeto a validación de costos y restricciones:

- WAF/reverse proxy o entrada segura.
- Aplicación web/API.
- Servicio de identidad con MFA para personal.
- Base de datos relacional administrada.
- Almacenamiento de documentos con cifrado, versionado y permisos.
- Servicio de búsqueda/validación.
- Integraciones/API con proveedores y notificaciones.
- Registro centralizado de auditoría y monitoreo.
- Backups cifrados y pruebas de restauración.
- Gestión segura de secretos.

La seguridad se diseña alrededor de identidad, autenticación y autorización por recurso, coherente con principios de Zero Trust. Para la aplicación web se propone usar ASVS como checklist de requisitos verificables y OWASP API Security Top 10 para las interfaces.

3.3 Controles de seguridad integrados

- MFA para usuarios internos.
- RBAC y mínimo privilegio.
- HTTPS/TLS.
- Validación de entrada.
- Registro de auditoría.
- Versionado de cotizaciones/documentos.
- Cifrado en tránsito y almacenamiento.
- Rate limiting/anti-abuso.
- Gestión de secretos.
- Backups y recuperación.
- Aprobación humana de resultados automatizados.

4. Gap Analysis, beneficios y riesgos

4.1 Resumen de brechas y cierre

Paquete	Brechas principales	Resultado esperado
P1	B03, B04, B05, B07, B08, B10, B11	Solicitudes estructuradas, historial único, roles y trazabilidad
P2	B01, B02, B09	Menor tiempo de búsqueda y validación técnica con evidencia
P3	B06, B07, B09, B10, B13	Cotización más rápida y documentos controlados
Enabler	B12	Mayor disponibilidad y recuperación

4.2 Beneficios

Negocio: menor tiempo operativo; reducción de reprocesos; respuesta comercial más consistente; mejor seguimiento de solicitudes.

Aplicaciones: información centralizada; estados y responsables visibles; reutilización de datos; menor dependencia de documentos aislados.

Seguridad: identidad central, mínimo privilegio, auditoría y mejor control de la información.

Gestión: posibilidad de medir tiempos de respuesta, volumen de solicitudes y estados del proceso.

4.3 Riesgos de implementación y mitigaciones

Riesgo	Impacto	Mitigación
Baja adopción del nuevo canal	Medio-Alto	Implantación gradual y mantener transición corta con canales actuales
Complejidad del motor de búsqueda	Alto	Empezar con reglas determinísticas + revisión humana
Resultados incorrectos de automatización	Alto	Aprobación humana y evidencia de fuentes
Mala configuración de permisos	Alto	Matriz RBAC, pruebas de autorización y revisiones periódicas
Dependencia del proveedor de plataforma	Medio	Contratos, exportación de datos y documentación de interfaces
Costos superiores a lo previsto	Medio	Piloto por fases y validación de costos antes de ampliar
Requisitos de privacidad incompletos	Alto	Incorporar resultados del Taller 6 antes de producción

5. Roadmap y gobierno de la transformación

Fase 0 — Validación (antes de comprar o construir)

- Recuperar C2 de Taller 3.
- Recuperar mapa de tecnología y riesgos de Taller 4.
- Incorporar brechas y obligaciones del Taller 6.
- Validar costos, restricciones, responsables y presupuesto con la Gerencia.
- Definir datos mínimos y política de retención.

Fase 1 — Quick wins

- Canal formal de solicitudes.
- Gestión comercial central.
- IAM/MFA/RBAC.
- Auditoría.
- Repositorio controlado.
- Backups y monitoreo.

Fase 2 — Automatización operativa

- Motor de búsqueda/validación.
- Integraciones seleccionadas con proveedores.
- Generador asistido de cotizaciones.
- Métricas del proceso.

Fase 3 — Optimización

- Ampliación de automatizaciones.
- Integración con nuevos proveedores.
- Analítica de tiempos y conversión.
- Revisión de costos, rendimiento y seguridad.

Gobierno

La Gerencia General debe actuar como patrocinador y validador de prioridades. Comercial debe ser dueño funcional del flujo de solicitudes/cotizaciones. Compras debe validar la lógica de búsqueda. TI/Seguridad debe gobernar identidad, permisos, auditoría, continuidad y controles técnicos.

6. Conclusiones

El diagnóstico muestra que la principal oportunidad de arquitectura de ISD Colombia no es incorporar tecnología aislada, sino **estructurar el flujo completo de información desde la recepción de la solicitud hasta la cotización**, reduciendo actividades manuales y creando trazabilidad.

El TO-BE propuesto conecta una plataforma de gestión comercial, búsqueda/validación asistida y generación controlada de cotizaciones, con seguridad transversal. La propuesta se diseñó para una empresa pequeña y por ello prioriza servicios gestionados y una implantación gradual, evitando una infraestructura innecesariamente compleja.

La solución final debe validarse contra los entregables originales de los Talleres 3, 4 y 6 antes de convertirse en diseño definitivo. En particular, los requisitos normativos y las restricciones de infraestructura no deben inferirse.

Referencias técnicas y normativas principales

- NIST CSF 2.0: <https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20>
- NIST SP 800-207 Zero Trust Architecture: <https://www.nist.gov/publications/zero-trust-architecture>
- OWASP ASVS: <https://owasp.org/projects/asvs>
- OWASP API Security Top 10: <https://api-security.owasp.org/>
- SIC - Ley 1581 de 2012: <https://sedeelectronica.sic.gov.co/transparencia/normativa/ley-estatutaria-1581-de-2012>